

The 24-hour clock starts 11 September

What actually becomes binding that day, why it is not optional, and the six things product management and counsel have to put in place before it — none of which is a coding problem.

OBLIGATION BEGINS 11 Sep 2026	WHAT BINDS Article 14	ENGINEERING WORK OWED None
EFFORT TO CLOSE ~2 hours		

01 · THE LAW

What becomes binding, precisely

The Cyber Resilience Act came into force in December 2024 with most of its weight deferred to **11 December 2027** — CE marking, the technical file, the essential requirements in Annex I. One article was pulled forward. From **11 September 2026**, Article 14 obliges a manufacturer to report **actively exploited vulnerabilities** and **severe incidents** in its products to ENISA and to the coordinating national CSIRT, through the EU single reporting platform, on a fixed clock:

24 h	Early warning From the moment we <i>become aware</i>. Not from the moment we understand it, reproduce it, or have a fix. A short notice that something is being exploited is enough — and is required.
-----------------	--

72 h

Notification

The product, the general nature of the exploit and the vulnerability, and any corrective or mitigating measures available or advised.

14 d

Final report

Within 14 days of a corrective or mitigating measure being available. For a *severe incident* rather than a vulnerability, the final report window is one month, and covers root cause and mitigation.

Article 14 carries a fourth duty that is easy to miss and lands in the same hours: **we must also inform affected users** of the vulnerability or incident and of any mitigation they can apply. If we do not do it in reasonable time, the CSIRT may do it for us — which means our customers would learn of a problem in our product from a government notice.

02 • WHY MANDATORY

Why this is not a best practice

Every other line on the compliance programme is something we decided to do well. This one is not ours to schedule, scope or defer. It is an obligation the Union places on the **manufacturer** of a product with digital elements — that is us, by name and by role — and it takes effect on a fixed date whether or not we are ready, whether or not we are CE marked, and whether or not anyone has asked us about it.

A regulation is not a standard we adopt. It is a clock, and we do not start it.

-
- **It is a regulation, not a directive.** It applies directly in every member state. There is no national transposition to wait for and no implementation grace period after 11 September.
 - **It reaches backwards.** The duty attaches to products we have *already* placed on the EU market, not only to what we ship next. A unit sold last year is inside the obligation; the customer's contract and its warranty status are irrelevant to it.
 - **The trigger is outside our control.** We do not choose when a vulnerability is actively exploited. The 24-hour clock is started by an event we learn about, at whatever hour we learn about it.
 - **It is enforced by market surveillance authorities**, whose powers include ordering a product withdrawn from the market. Penalties for breaching the Article 13/14

obligations sit in the top band of the CRA's fine structure — the figure is the kind of number counsel should confirm rather than take from a memo, but the order of magnitude is existential for a company our size.

- **Failure is visible.** Missing a CE mark is discovered in an audit. Missing a 24-hour report is discovered in the middle of a live exploitation event, in front of the customer it affects.

Three ways this gets misread

“We are not CE marked yet, so the CRA does not reach us until 2027.”

NO. Article 14 was deliberately pulled forward, separately from everything else. The 2027 date governs marking, the technical file and the Annex I requirements. The reporting duty is not waiting for them.

“Our customer agreements cover how we handle security issues.”

NO. The duty runs to ENISA and a national CSIRT, not to the customer. No contract we sign with a buyer discharges it, and no buyer can waive it on our behalf.

“We will deal with it if it ever happens.”

NO. The whole obligation is a 24-hour clock. There is no version of “deal with it then” that fits inside one working day if the mailbox, the duty officer, the CSIRT routing and the platform login all have to be created first.

03 • CORRECTION

One thing our own plan gets slightly wrong

Both `cra-compliance-plan.md` and the owner-facing summary describe 11 September as the date from which *“a researcher must have a published way to tell us”*. That framing is off, and it is worth fixing before it drives the work.

WHAT THE TWO DATES ACTUALLY COVER

The duty to **run a coordinated disclosure policy and publish a contact address** is Annex I Part II points 5 and 6 — and Annex I applies from **11 December 2027**.

What lands on **11 September 2026** is the **outbound** reporting duty: us, to ENISA and a CSIRT, on a 24-hour clock.

This does not weaken the case for doing the mailbox this week — it strengthens it. The mailbox is not the obligation; it is the **tripwire that makes the obligation performable**. The realistic way a small manufacturer first learns that a vulnerability in its fielded units is being exploited is that somebody writes and says so. A 24-hour clock we cannot hear start is a 24-hour clock we miss.

But it does mean the three steps currently on the plan — create mailbox, publish files, verify from outside — are **necessary and not sufficient**. They build the tripwire. They do not build the response. Section 05 is what is missing.

04 · THIS WEEK

The mailbox, in this order

Unchanged from the existing plan, because the existing plan is right about it. The ordering is load-bearing.

1 Create `security@joralllc.com` as a Workspace group

A group, not a personal alias — a personal address fails the first time that person is on leave. Members: product management **and at least one engineer**. Alias `psirt@` to the same group; it costs nothing and catches reporters who follow PSIRT convention. Confirm delivery from outside the domain.

2 Publish the two prepared files

`security.txt` at `/.well-known/security.txt` over HTTPS as text/plain — not an attachment, not redirected to a marketing page. The policy at exactly `https://joralllc.com/security-policy`, because that is the URL `security.txt` names. Both files are written, validated by a 16-check script, and waiting in `media/joral/disclosure/`.

3 Verify from outside the company

Fetch both URLs from a network that is not ours, and send a test report to the address from a personal account. Until mail is actually received, the row is not closed.

DO NOT PUBLISH BEFORE THE MAILBOX EXISTS

A researcher who writes to an advertised address and hears nothing concludes we do not answer. What they typically do next is publish the vulnerability rather than report it — which converts a private report into a public zero-day and, after 11 September, into a reportable event with a 24-hour clock already running.

05 · THE GAP

Five things the current plan does not cover

Each is a decision or an errand. None needs engineering time, and none takes longer than the meeting it is decided in.

A named duty officer, and a deputy PM

A 24-hour clock needs a person, not a group. Name who reads the mailbox each working day, who covers holidays and weekends, and who has standing authority to file an early warning *without* waiting for the CTO. Nothing in the 24-hour report commits us to a finding — it says we are aware and looking — so gating it on the CTO's availability is the single most likely way we miss it.

Establish which CSIRT we report to LEGAL

Reports go to ENISA *and* the CSIRT designated as coordinator, which follows the manufacturer's main establishment in the Union — or the establishment of its EU authorised representative, for a manufacturer based outside it. As a US company, we need counsel to tell us which CSIRT that is for us, and whether an authorised representative is required or advisable. This is the one item with a real chance of taking longer than an hour, so start it first.

Get access to the single reporting platform before we need it PM

The report is filed through the EU single reporting platform, which is due to be operational on the same date. Whatever registration or account it requires, do it in a quiet week. Nobody should be creating a login for the first time inside a 24-hour window.

Draft the two notices in advance PM

A fill-in-the-blanks early warning, and a customer notice for the Article 14(8) duty to inform affected users. Both are twenty minutes of writing now and an hour we will not have later. The customer notice needs a distribution list — who we email when a fielded unit is affected — which we should confirm exists.

One 30-minute drill, before 11 September PM + ENG

Send a fabricated report to the new mailbox and walk it end to end: who saw it, how fast, which builds are affected, what the early warning would have said, who signs it, who tells the customer. Every serious defect this programme has found came from running something rather than reading it. This is the same principle applied to the process rather than the product.

06 · OWNERS

Who moves what

ITEM	OWNER	EFFORT	BOUND TO 11 SEP
Mailbox, publish, verify	Product management + WEB	1 hour	Yes
Duty officer + deputy named	Product management	A decision	Yes
CSIRT routing / authorised rep	Legal	Counsel time	Yes — start first
Reporting-platform access	Product management	Under an hour	Yes
Notice templates + customer list	Product management	30 minutes	Yes
Tabletop drill	PM + one engineer	30 minutes	Yes

ITEM	OWNER	EFFORT	BOUND TO 11 SEP
Sign firmware signing policy; key ceremony	Carl CTO	Signature + 1 hour	No — blocks first shipment
Confirm five-year support period	Carl CTO	A decision	No — blocks first shipment
EULA review, jurisdiction, support@	Legal	Counsel time	No

The bottom three are the existing item 2 of the remaining-work list, unchanged. They belong in the same conversation because it is one meeting, not three — but only the top six are dated.

07 · SCHEDULE

Seventeen days

THIS WEEK	Mail counsel the CSIRT-routing and authorised-representative question. It is the only item whose duration we do not control, so it goes first even though it is the least visible.
SAME DAY	Create the Workspace group , name the duty officer and deputy in the same message. Then publish the two files, then verify from outside.
ONE MEETING	Carl signs the firmware signing policy and confirms the five-year support period as CTO; the two product questions — audit-log forwarding, scaling-factor rejection — get answered in the same hour. Not deadline work, but it is the meeting that is already needed.
BY 4 SEP	Platform access obtained, templates drafted, customer distribution list confirmed. A week of slack before the date, deliberately.

BY 9 SEP

Run the drill. Fix whatever it exposes — it will expose something, and the point of running it two days early is that there is room to.

11 SEP 2026

Obligation begins. Nothing should happen on this day. That is the objective.

08 · ASSETS

What makes this cheap for us

A 24-hour clock is expensive for a manufacturer that cannot answer “*which builds are affected?*” in the first hour. We can, and that was deliberate:

- Every release carries a **bill of materials tied to its build identifier**, cross-checked against the CVE report so the two cannot describe different images. A component named in a report maps to a build list without an investigation.
- Every release is **screened against public vulnerability databases** at the build gate, so “did we already know?” has a recorded answer.
- The **signed A/B update path is proven on hardware**, including the downgrade refusal — so “a corrective measure is available” is a thing we can actually make true inside the 14-day window, once the key ceremony has happened.
- The **fix-note format is already written** into both products' policies: affected builds by identifier, impact in plain language, the corrective update, free of charge. That is most of an Article 14(8) customer notice.
- Both disclosure files are **validated by a script that fails the build** if the published address ever drifts from the six shipped surfaces that carry it — and fails 60 days before the `security.txt` expiry lapses.

All eight Annex I Part I product properties are met and demonstrated on hardware. The gap is not the product. It is that nobody is currently on the hook to open an inbox.

09 · OPEN

Questions this memo cannot answer

- **Have we placed a product on the EU market yet?** The Article 14 duty attaches to products placed on the Union market. If no unit has been, the clock has nothing to attach to on 11 September — and attaches the moment the first one ships. This changes how alarmed to be; it does not change a single action above, because the mailbox has to exist before first shipment either way.
- **Are we the manufacturer for every unit, or is anyone reselling under their own name?** A distributor who puts their brand on our hardware becomes the manufacturer for CRA purposes, which changes who owes the report.

- **Does an EU authorised representative make sense for us regardless?** Counsel's call, and it is the same conversation as the CSIRT-routing question.

Article and deadline detail from the Commission's CRA reporting-obligations guidance and the Article 14 text. Fine bands, CSIRT routing for a non-EU manufacturer, and market-placement status are flagged above as counsel's calls rather than stated as settled.